

Федеральное государственное автономное
образовательное учреждение высшего образования
«Национальный исследовательский университет ИТМО»

Информационная безопасность

Работа №5

«Аудит паролей с помощью менеджера паролей»

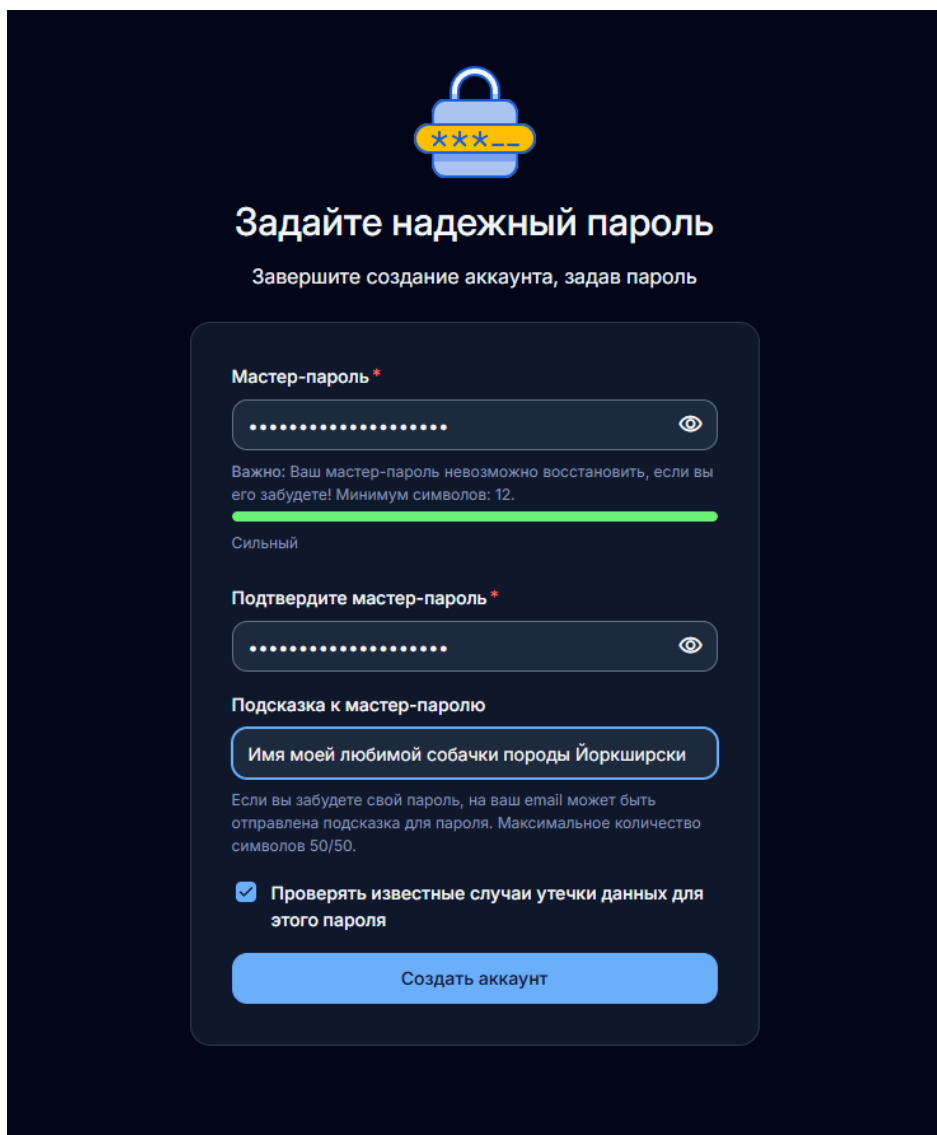
Трикашный Михаил

Группа: Р3406

Выполнение

Создание и настройка менеджера паролей

Создадим аккаунт на BitWarden: укажем свою почту, подтвердим ее, придумаем мастер-пароль, как показано на рисунке 1:



The screenshot shows the BitWarden account creation interface. At the top, there is a logo of a blue padlock with three yellow stars. Below the logo, the text "Задайте надежный пароль" (Set a reliable password) is displayed in white, followed by the subtitle "Завершите создание аккаунта, задав пароль" (Complete account creation by setting a password). The main form area is a dark blue rounded rectangle containing the following elements:

- Мастер-пароль *** (Master password *): A text input field with a blue eye icon for toggling visibility. Below the field, a warning message states: "Важно: Ваш мастер-пароль невозможно восстановить, если вы его забудете! Минимум символов: 12." (Important: Your master password cannot be recovered if you forget it! Minimum symbols: 12.). A green progress bar indicates the password strength, and the word "Сильный" (Strong) is shown below it.
- Подтвердите мастер-пароль *** (Confirm master password *): A second text input field with a blue eye icon.
- Подсказка к мастер-паролю** (Master password hint): A text input field containing the example "Имя моей любимой собаки породы Йоркширски" (Name of my favorite dog of the Yorkshire breed).
- A note below the hint field: "Если вы забудете свой пароль, на ваш email может быть отправлена подсказка для пароля. Максимальное количество символов 50/50." (If you forget your password, a password hint may be sent to your email. Maximum number of characters 50/50.).
- A checked checkbox with the text: "Проверять известные случаи утечки данных для этого пароля" (Check known data leak cases for this password).
- A large blue button at the bottom labeled "Создать аккаунт" (Create account).

Рисунок 1 — Ввод мастер-пароля для создания учетной записи

После успешного создания учетной записи, можем увидеть хранилище BitWarden, как показано на рисунке 2:

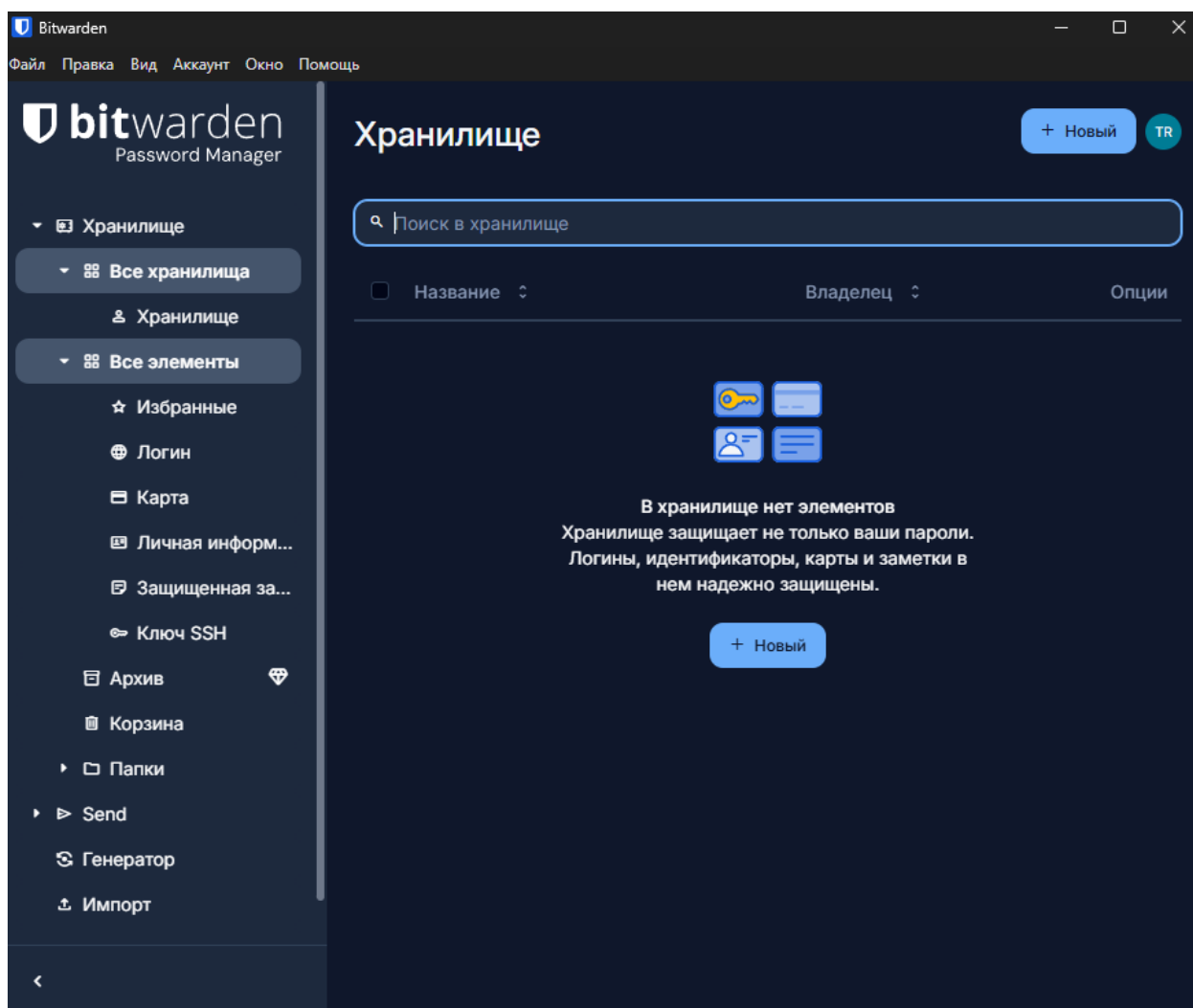


Рисунок 2 — Основное окно хранилища BitWarden

Проверим, не были ли они скомпрометированы мои пароли с помощью сервиса <https://haveibeenpwned.com/>. Как показано на рисунке 3, не обнаружено утечек, связанных с моей основной почтой:

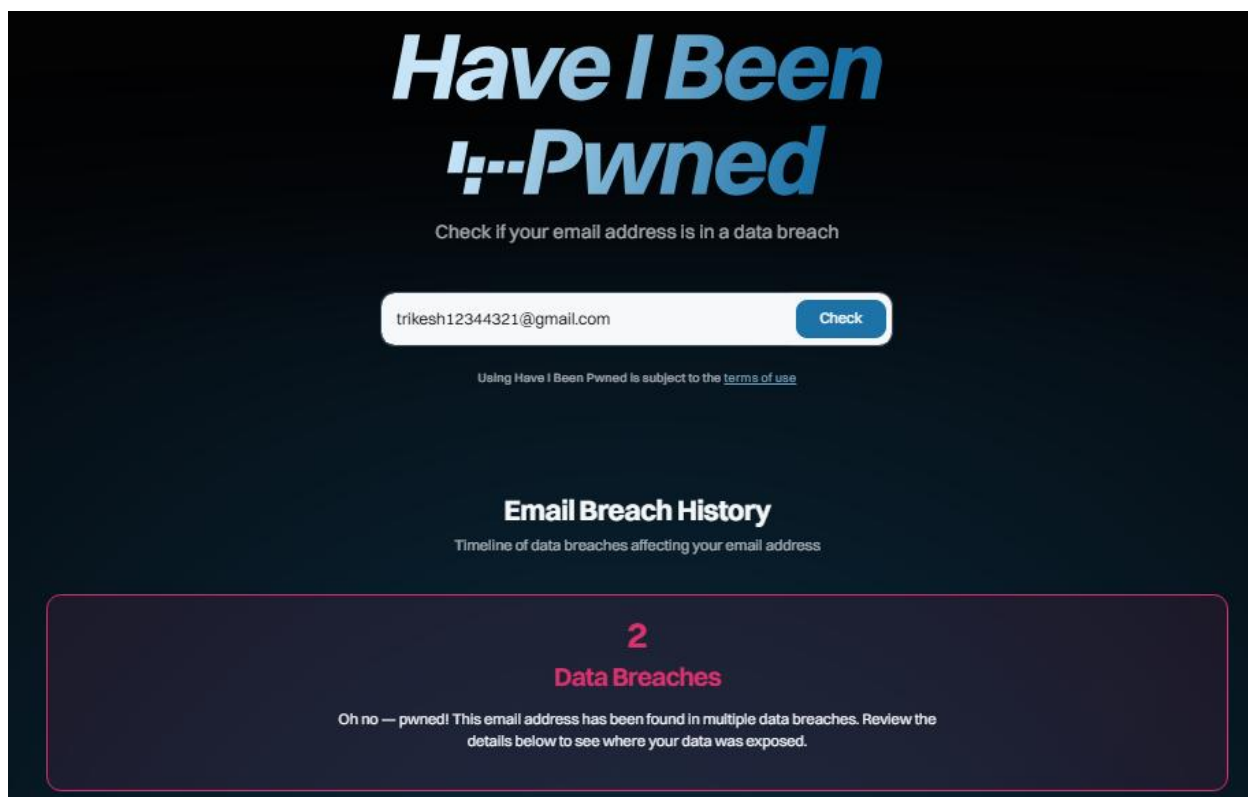


Рисунок 3 — Проверка на утечки для основной почты

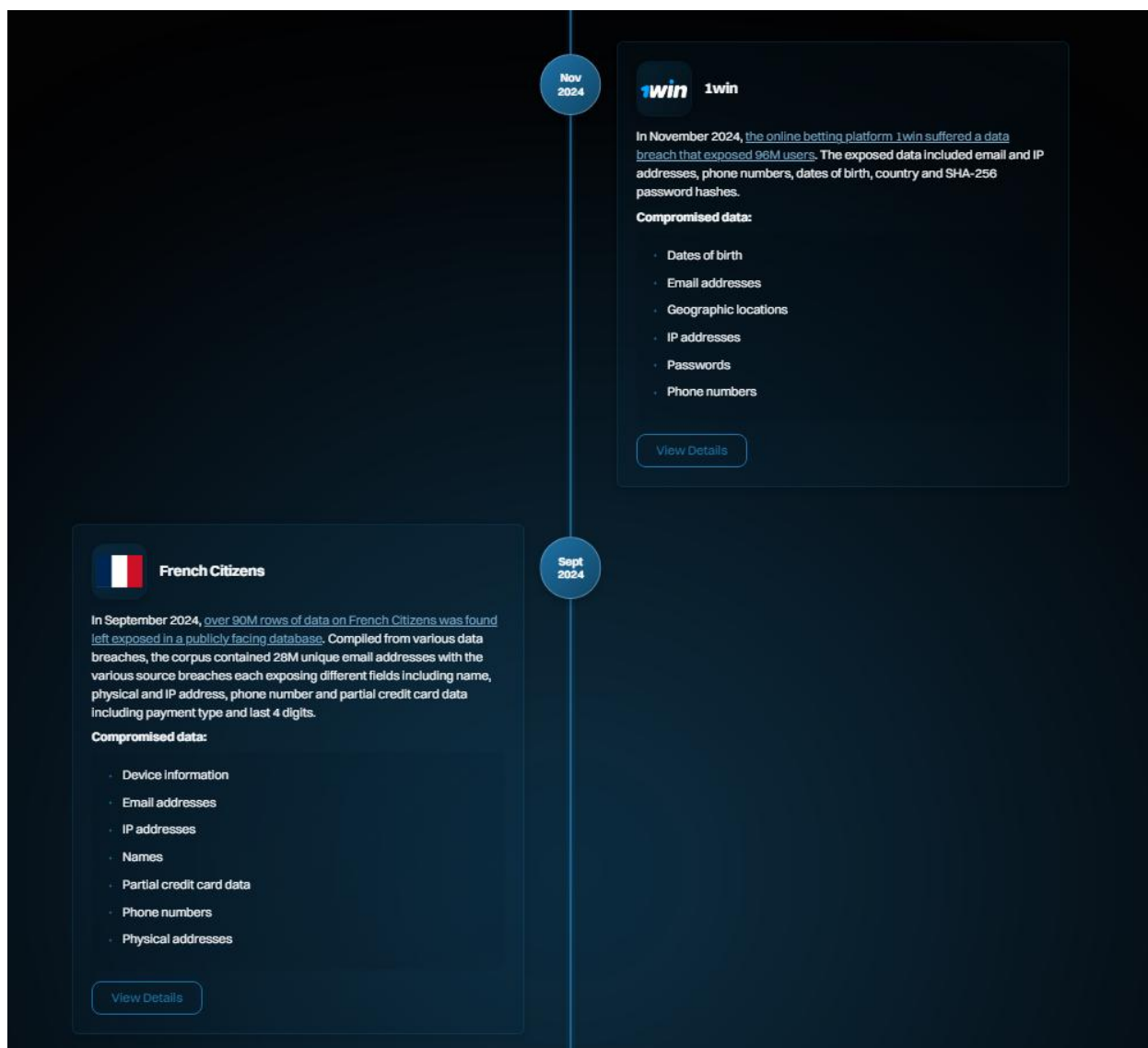


Рисунок 3.5 — Где были утечки.

Аудит и замена паролей для 5 аккаунтов

О нет! Оказывается мой email был скомпрометирован 😞

Посмотрев утечки самая последняя была в 2024 году, тогда я использовал слабый пароль из 9 символов, разных регистров и без спец. символов.

Я вспомнил, что для 5 моих аккаунтов на разных площадках используется все еще этот пароль, в vk, roblox, github, discord и itmo

Итак, будем менять пароли для следующих платформ:

1. vk.com

Как показано на рисунке 4, пароль был изменен:

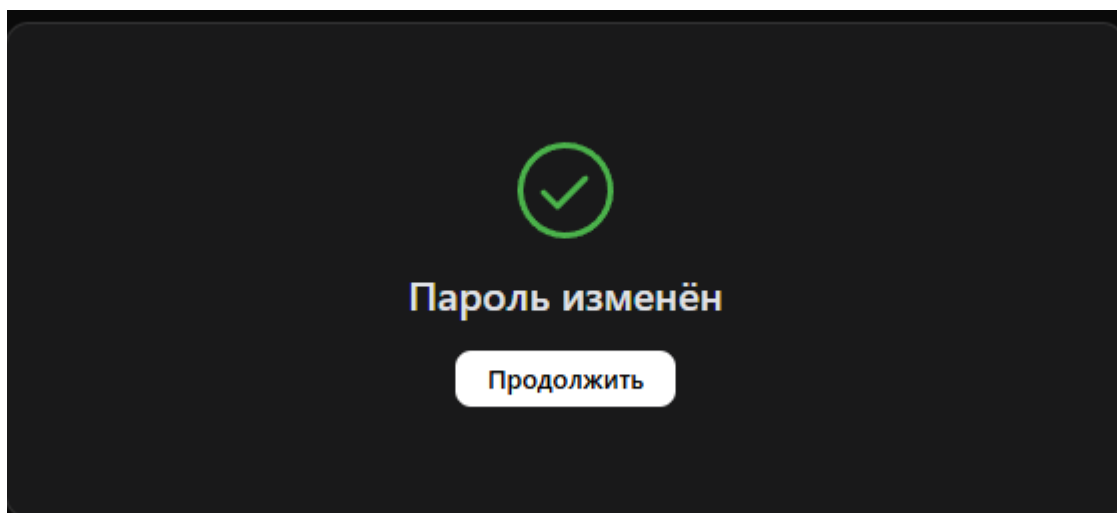


Рисунок 4 — Сброс пароля для VK

2. roblox.com

Как показано на рисунке 5, пароль был изменен:

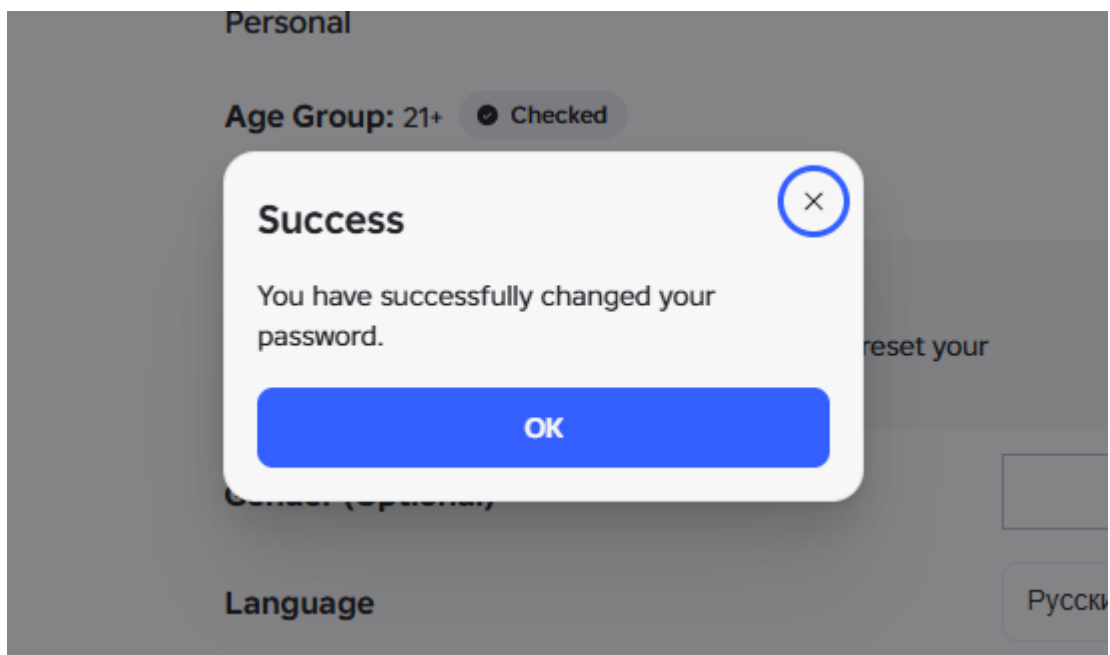


Рисунок 5 — Сброс пароля для Roblox

3. github.com

Как показано на рисунках 6, пароль был изменен:

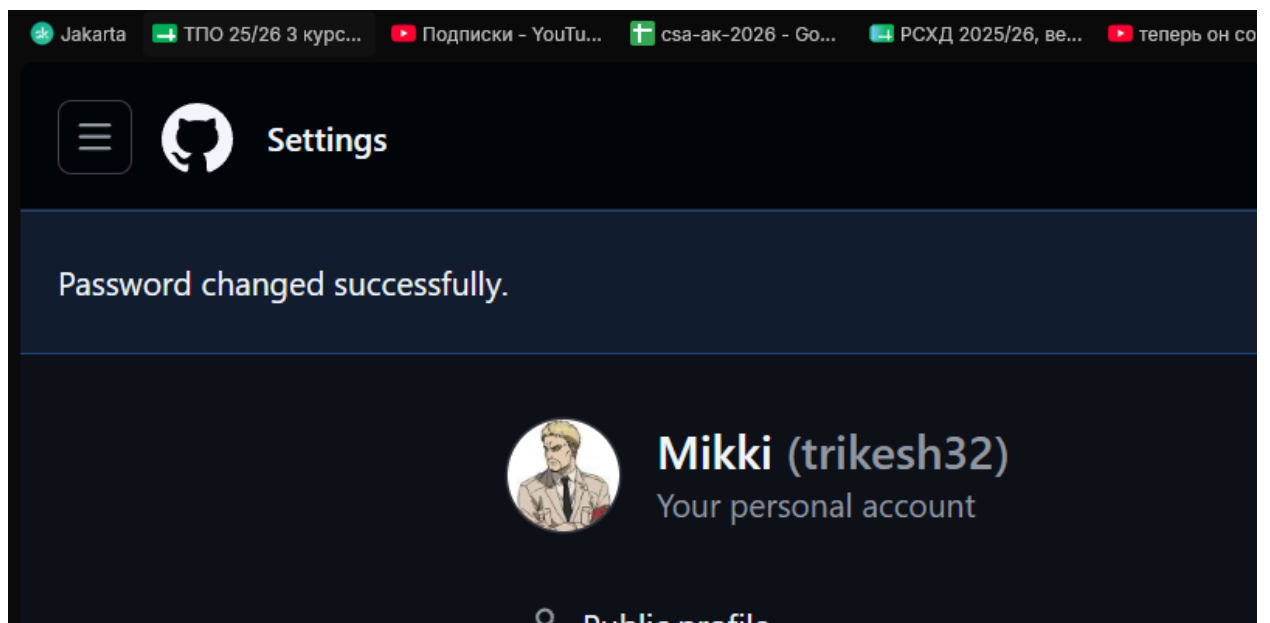


Рисунок 6— Сброс пароля для github

4. discord.com

Как показано на рисунке 7, пароль был изменен:

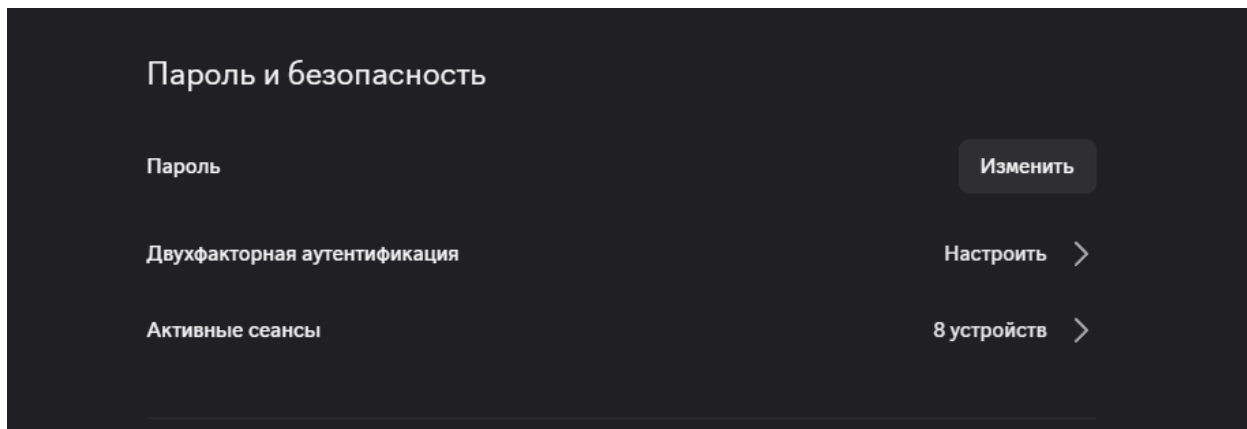


Рисунок 7 — Пароль Discord был изменен

5. my.itmo.ru

Как показано на рисунке 8, пароль был изменен:

A screenshot of the 'my.itmo.ru' password change form. It has a light gray background. There are three input fields: 'Текущий пароль' (Current password), 'Новый пароль' (New password), and 'Подтверждение пароля' (Confirm password). The first two fields are filled with dots. The third field is partially filled with dots and has a blue shield icon on the right. Below the third field, there is a dark gray banner with the text 'Нет элементов для отображения' (No items to display) and a blue button with a plus sign and the text '+ Новый логин' (+ New login).

Рисунок 8 — Сброс пароля для itmo

После замены всех паролей на пяти аккаунтах, добавим аутентификационные данные в хранилище, как показано на рисунке 9:

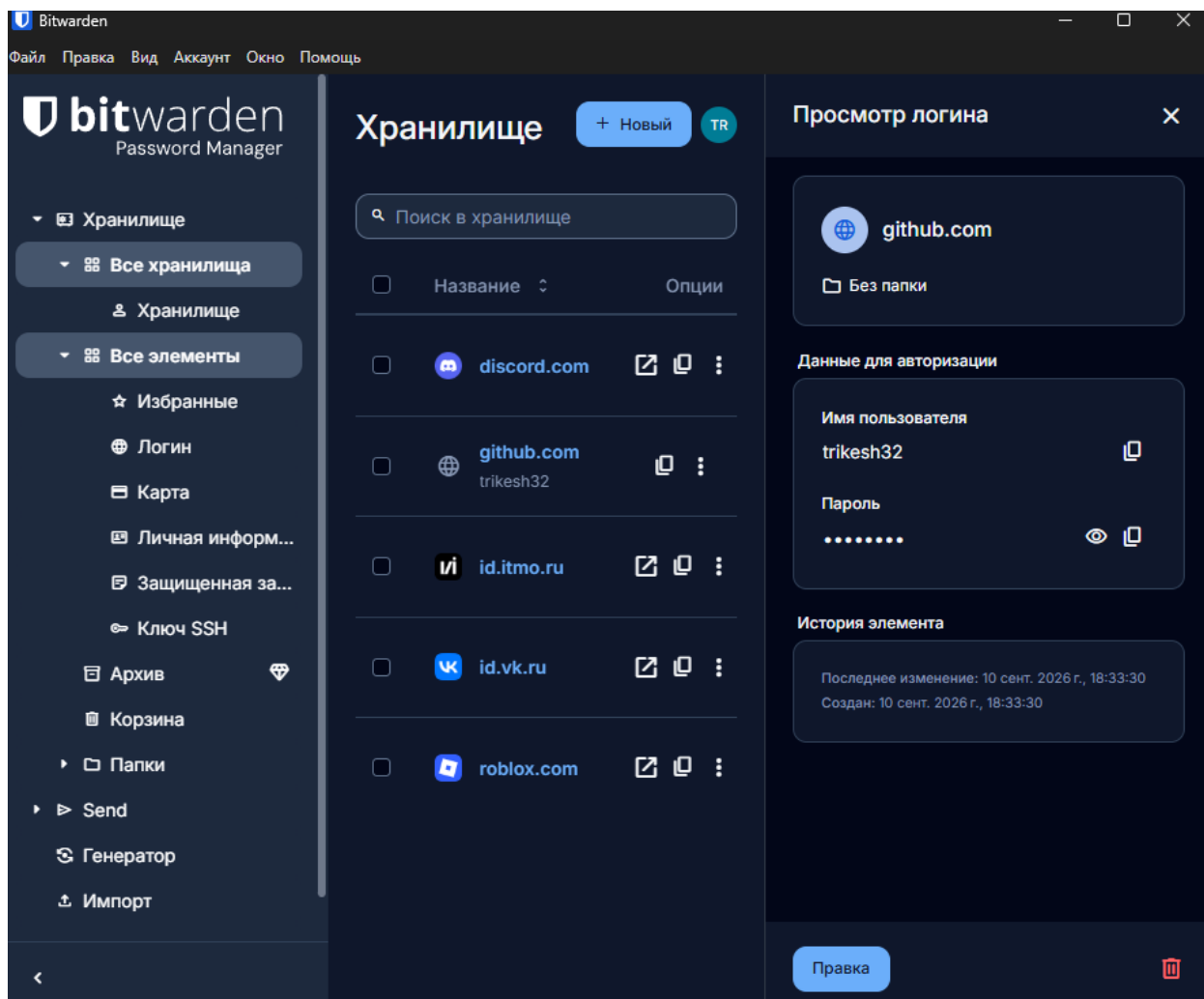


Рисунок 9 — Записи в BitWarden аккаунтов с новыми паролями

Анализ паролей (что было слабым)

Проведя аудит паролей, я в первую очередь отказался повторяющихся и слабых паролей. Анализ показал, что, такая модель защиты своих данных крайне слаба и уязвима даже для одной утечки.

В рамках этой работы я устранил этот ключевой недостаток, внедрив принцип децентрализации шаблонов. Новые пароли генерируются случайно, с использованием всего разнообразия символов на клавиатуре. Такой подход делает их устойчивыми не только к простому перебору, но и к сложным алгоритмам, которые анализируют возможные закономерности в структуре пароля.

Двухфакторная аутентификация

Двухфакторная аутентификация (или 2FA, Two-Factor authentication) – это метод защиты учетной записи, предполагающий предоставление сразу двух различных типов доказательств, чтобы убедиться, что пользователь – тот, за кого себя выдает.

Эти доказательства (факторы) бывают трех типов:

1. Что-то, что человек знает (знания) — пароль, пинкод.
2. Что-то, что у человека есть (владение) — одноразовый код из приложения-аутентификатора (тот же BitWarden или Google Auth), SMS на телефон, может даже физический ключ безопасности.
3. Что-то, чем человек является (биометрия) — отпечаток пальца или сканер лица применяются наиболее часто.

Двухфакторная аутентификация (2FA) служит дополнительным барьером безопасности, основанным на факторе владения. Это означает, что даже если злоумышленник получит пароль, этого будет недостаточно для доступа. Ему потребуется также физический доступ к вашему мобильному устройству или приложению, генерирующему одноразовые коды.

Хотя можно использовать универсальные менеджеры вроде Bitwarden или приложения-аутентификаторы (например, Google Authenticator), в данной работе мы рассмотрим приложение-аутентификатор на примере Яндекс ID для аутентификации в Github.

Приступим к настройке. Изначальное состояние показано на рисунке 10:

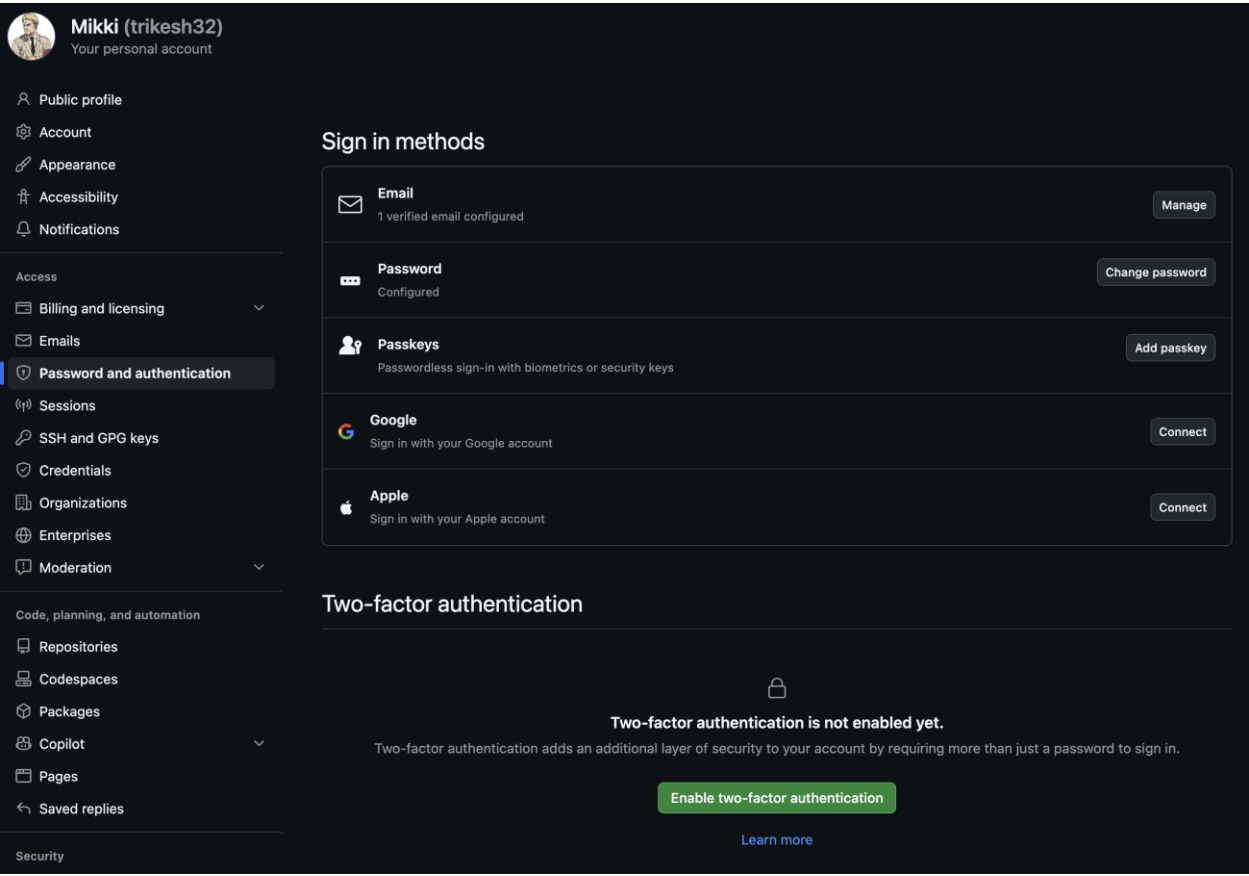


Рисунок 10 — До установки мобильного аутентификатора

Далее устанавливаемый мобильный аутентификатор, сканируем QR код и вводим получившийся код.

Дальше нам предлагают скачать коды для полного восстановления аккаунта в случае потери мобильного устройства, как показано на рисунке 17:

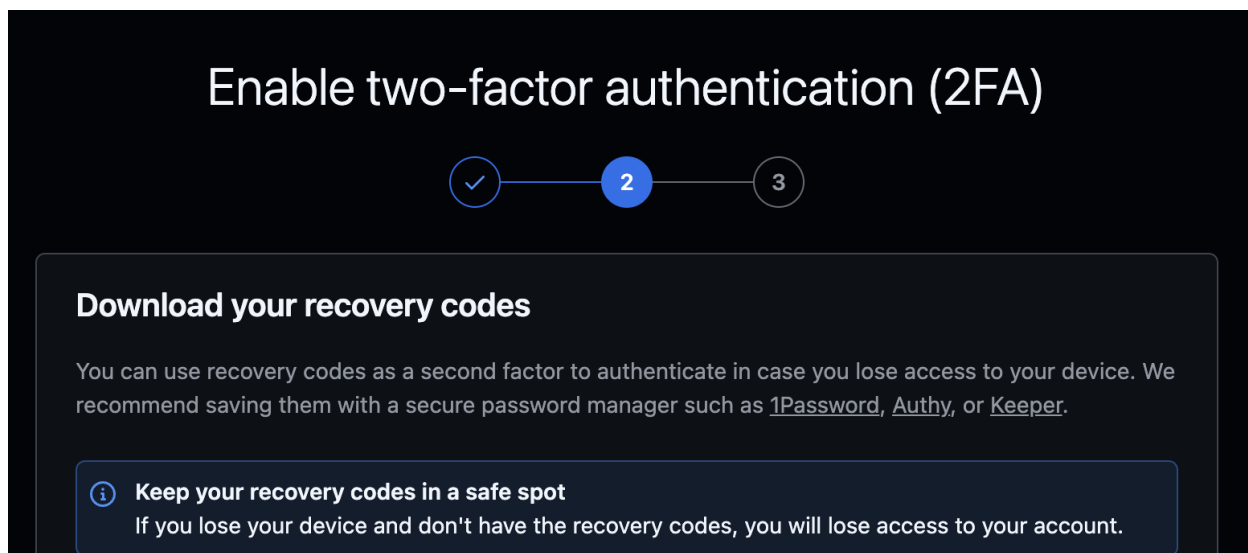


Рисунок 11 — Коды восстановления, сами коды я вам не покажу :)

Теперь видим, что одноразовые коды начали приходить в приложение аутентификатор

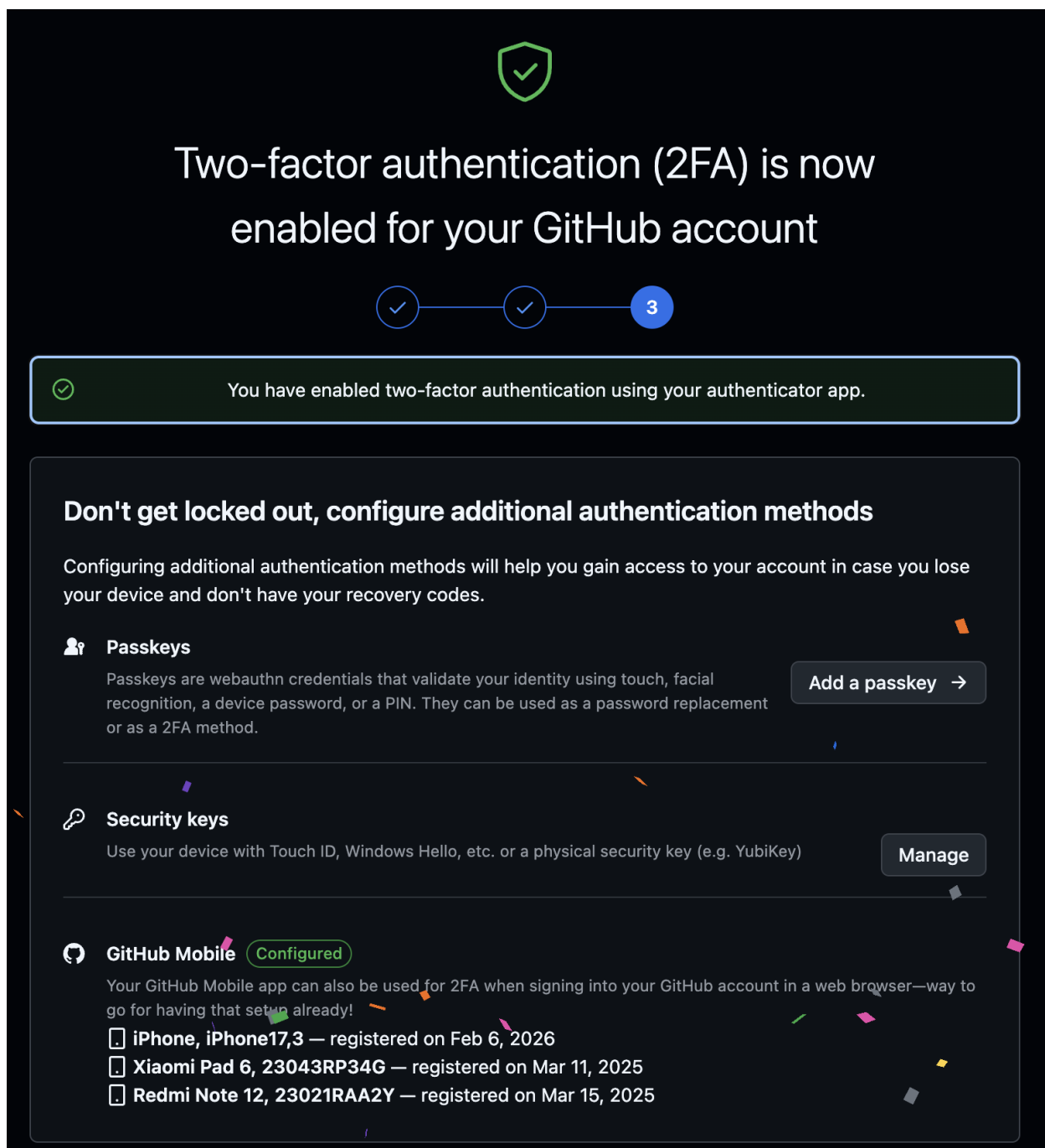


Рисунок 12 — Результат после настройки 2FA